Sécurité Informatique

Plan du cours :

Chapitre 1 : Principe de la Sécurité Informatique

Chapitre 2 : Cryptographie Symétrique Classique

Chapitre 3 : Cryptographie Symétrique Moderne

Chapitre 4 : Cryptographie Asymétrique

Chapitre 5 : Hachage et Signature Numérique

Chapitre 6 : Sécurité des Applications Web

Chapitre 1 : Principe de la Sécurité Informatique

1) Objectif

L'objectif de la sécurité informatique est de protéger les machines (ordinateurs, serveurs, smartphones, tablettes, etc.), les informations stockées, les équipements réseau (tels que les routeurs) et les échanges des données sur le réseau contre tout usage illicite, et assurer le bon fonctionnement du système informatique.

2) Vocabulaire

a) Les menaces

Une menace est une source potentielle d'incident qui peut résulter en un dommage au système ou un accés illicite (càd non autorisé) aux données.

b) Les vulnérabilités

Un système est dit vulnérable s'il a des failles de sécurité (càd s'il est défaillant). Un système qu'on peut attaquer est un système vulnérable. Dans le cas contraire, le système est dit fiable.

Exemples de failles de sécurité :

- Ordinateur sans mot de passe
- Compte Linux avec mot de passe par défaut
- Serveur de base de données protégé par un mot de passe par défaut
- Envoi en clair des fichiers sur un réseau partagé

c) Les attaques

Une attaque est l'action d'exploiter les failles d'un système pour accéder d'une manière illicite (càd non autorisée) aux données ou pour empêcher le bon fonctionnement du système informatique.

Exemples d'attaques :

- Ecoute et interception des données échangées sur le réseau
- Modification des données échangées
- Suppression des données de l'ordinateur victime
- Interdire le bon fonctionnement d'un réseau informatique

3) Classification des attaques

Les attaques peuvent être classées en deux catégories : les attaques passives et actives

a) Attaques passives

Une attaque passive tente d'apprendre ou de faire usage de l'information, mais ne modifie pas les données interceptées. Cette attaque consiste à espionner les données échangées sur le réseau.

Il y a deux types d'attaques passives :

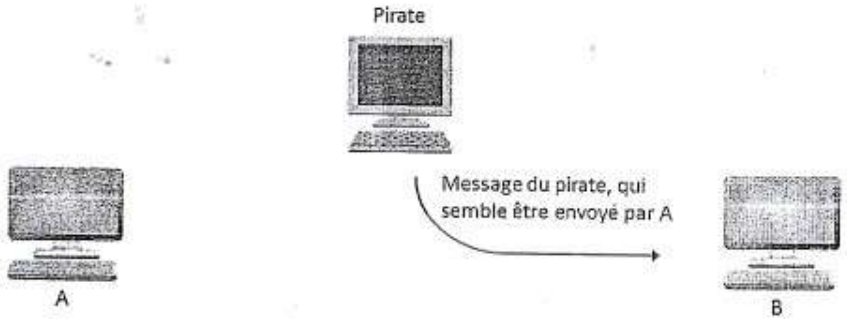
- Lecture des messages : les données sont envoyées en clair (mots de passe, conversations téléphonique, fichiers, etc.) et sont compréhensibles par l'attaquant. Pour se protéger contre cette attaque, on utilise le cryptage (càd chiffrement) des données.
- Analyse du trafic : si les messages sont chiffrés, l'attaquant ne peut pas les lire mais peut analyser le trafic. L'analyse du trafic permet de déterminer certaines informations, telles que l'emplacement et l'identité des machines communicantes en utilisant leurs adresses IP.

Remarque : les attaques passives sont difficiles à détecter car elles ne comportent aucune modification des données. Typiquement, les données sont envoyées et reçues de façon apparemment normale, et ni l'émetteur ni le récepteur ne sont conscients qu'un tiers a lu les messages ou a analysé le trafic.

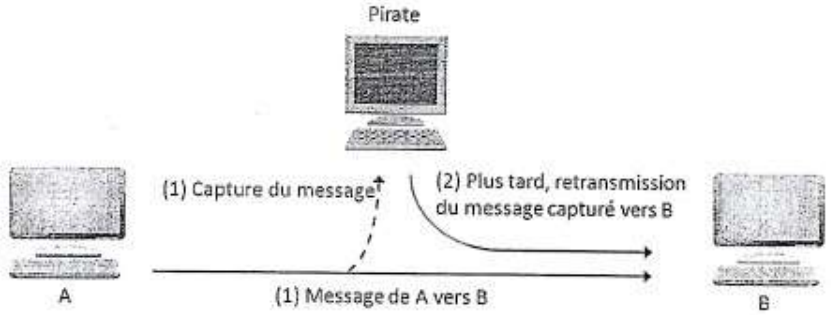
b) Attaques actives

Une attaque active tente de modifier les ressources du système ou affecte son bon fonctionnement. L'attaquant réalise une certaine modification des données échangées et peut même générer des faux messages. Il y a 4 types d'attaques actives :

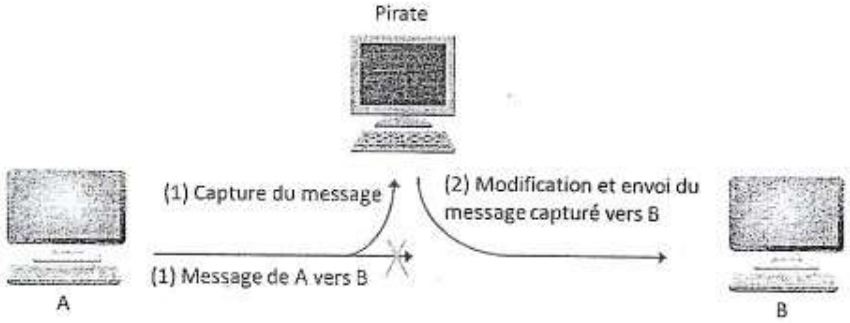
- **Usurpation d'identité** : une entité prétend être une entité différente. C'est l'origine des attaques actives. Les autres catégories sont des cas particuliers de l'usurpation d'identité. ***Exemple*** : un pirate envoie un message à la machine B en indiquant l'adresse de la machine A dans le champ « émetteur du message ».



- **Rejeu** (en anglais : replay) : Cette attaque est réalisée en deux phases. D'abord la capture passive d'un message (chiffré ou non). Ensuite, la retransmission ultérieure de ce message pour produire un effet non autorisé. ***Exemple*** : rejeu d'une transaction bancaire dont le pirate est bénéficiaire.



- **Modification des messages** : Le pirate modifie le contenu du message original pour produire un effet non autorisé. ***Exemple*** : Modifier le nom du bénéficiaire d'une transaction bancaire.



- **Déni de service** : L'objectif de cette attaque est d'interrompre ou dégrader le service d'un système informatique. Exemple 1 : Le pirate réserve toutes les adresses IP d'un réseau avec l'attaque « DHCP starvation ». Exemple 2 : Le pirate envoi une grande quantité de données inutiles sur un réseau pour le surcharger et réduire son débit.

Remarque : Il est difficile de garantir une protection absolue contre les attaques actives à cause des vulnérabilités au niveau hardware, logiciel et protocolaire. Ainsi, un système informatique doit être capable de détecter les attaques actives et de se remettre de toute perturbation. Si la détection a un effet dissuasif (exemple : sanction pénal de l'attaquant), cet effet peut limiter les attaques.

4) Outils d'attaque

a) Scanners réseau

Ce sont des outils capables d'écouter le trafic du réseau et de scanner les vulnérabilités des machines connectées. Exemple : Wireshark (scanner de trafic) et nmap (scanner de vulnérabilités).

b) Logiciels malveillants

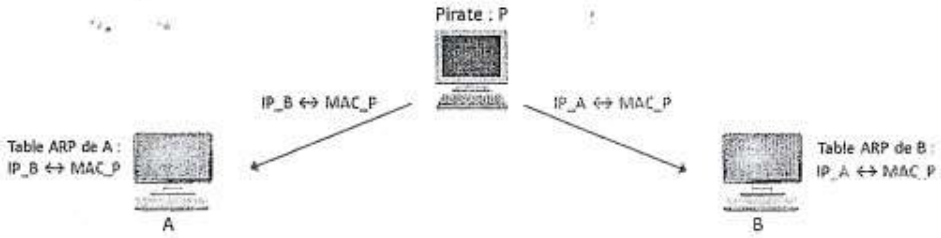
Ces logiciels ont généralement un objectif malicieux tel que : espionner les données, contrôler la machine victime à distance, détruire ou modifier les données de l'ordinateur infecté, envoyer plusieurs requêtes à un serveur web pour le saturer.

Parmi les logiciels malveillants, il y a :

- **Virus** : c'est une portion de programme qui se reproduit en se copiant dans le code d'autres programmes ordinaires. Un programme qui contient un virus est un programme infecté. Lorsque le programme infecté est exécuté, le virus est exécuté lui aussi. Le virus peut ensuite se propager à d'autres ordinateurs à l'aide des programmes infectés.
- **Ver** : un ver est un programme entier qui se reproduit et se propage à l'intermédiaire des utilisateurs. Contrairement à un virus, un ver n'a pas besoin d'un logiciel hôte pour se dupliquer.
- **Cheval de Troie** (en anglais : Trojan) : C'est un programme qui semble effectuer une fonction utile, mais qui a une fonction illicite non déclarée (cachée).

5) Exemples d'attaques

- **DoS** (Denial of Service) : une attaque visant à dégrader ou rendre indisponible les services d'un système informatique.
- **DDoS** (Distributed DoS) : lorsqu'une attaque DoS est réalisée par plusieurs machines simultanément, on l'appelle DDoS.
- **DHCP Starvation** : le pirate réserve toutes les adresses IP d'un réseau. Ainsi, les nouveaux utilisateurs ne peuvent pas obtenir des adresses IP et ne peuvent pas se connecter au réseau.
- **ARP Spoofing** : cette attaque intervient lorsqu'une machine pirate communique une fausse correspondance « Adresse IP – Adresse MAC » à une machine victime.



- **Attaques par injections SQL** : inserer un code SQL dans le formulaire envoyé au serveur web. **Conséquences** : authentification sans mot de passe, destruction possible de la base de données, exécution arbitraire de code, etc. Example d'authentification sans mot de passe en PHP :

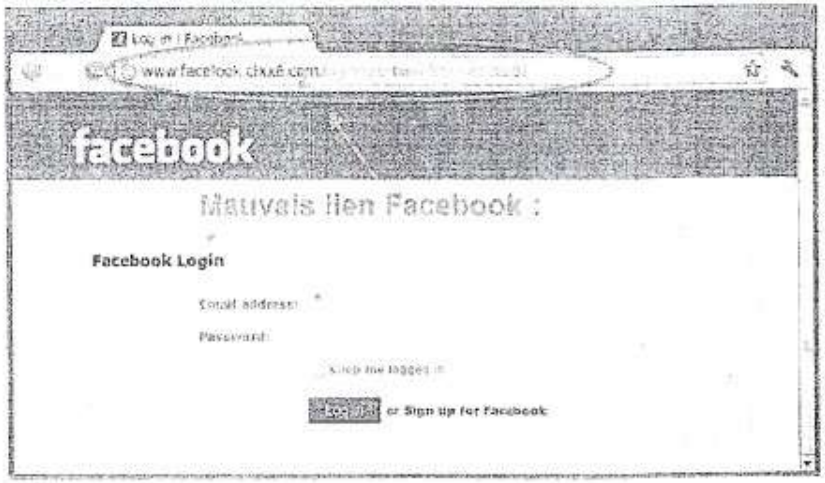
```
$username = $_POST['username'];
$password = $_POST['password'];
$sql = "SELECT * FROM users WHERE name='$username' AND password='$password';";

$resultat = $connexion->query($sql);

if($row = $ resultat->fetch_assoc()) {
    echo "Utilisateur authorisé";
}
else {
    echo "Utilisateur interdit";
}
```

Si l'utilisateur envoye « username=ali » et « password=blue552 », la requête sql devient :
`$sql = "SELECT * FROM users WHERE name='ali' AND password='blue552';"`
Si l'utilisateur envoye « username=ali';-- » et « password=12345 », la requête sql devient :
`$sql = "SELECT * FROM users WHERE name=' ali';--' AND password='12345';"`

- **Phishing** : consiste à piéger les victimes par le biais d'un email semblant provenir d'une entreprise de confiance (banque, site de commerce, etc.). L'email demande aux victimes de mettre à jour des informations sensibles et les envoi à une page semblable à l'originale :



6) Outils de protection

Il y a plusieurs outils de protection contre les attaques. On peut citer :

a) Antivirus : cherche les codes malveillants dans les logiciels disponibles

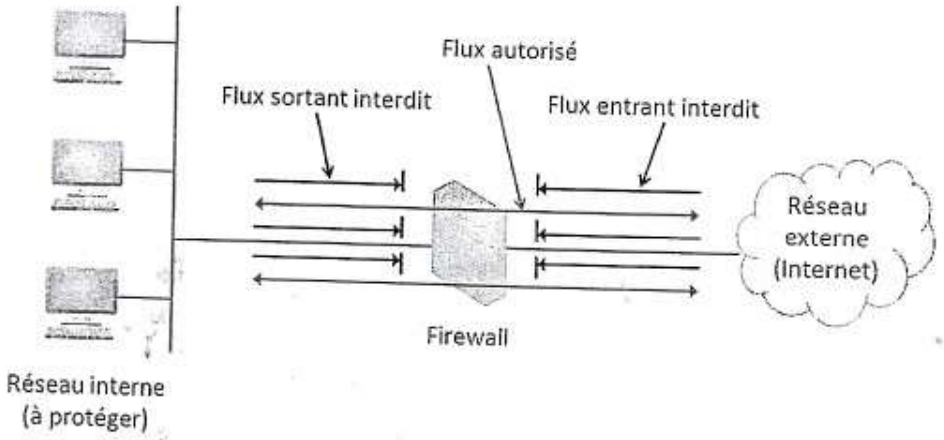
b) Anti-malware : protège contre les virus, ver, cheval de Troie, etc.

→ Les antivirus de nos jours sont des anti-malwares

c) Système de détection des intrusions (IDS : Intrusion Detection System) : détecte et signale les activités anormales ou suspectes sur le réseau surveillé. Exemple de IDS : Snort.

d) Firewall (pare-feu)

Un Firewall est un système (programme) permettant de protéger un réseau privé de certaines intrusions provenant d'un réseau externe. Un Firewall peut exister sur un routeur ou sur un ordinateur. Il permet de filtrer les paquets entrants et sortants. Il est également placé entre le réseau à protéger (réseau interne) et le réseau externe. Il ne protège pas contre une attaque venant du réseau interne.



Un Firewall contient un ensemble de règles de filtrage à appliquer sur des paquets. Une règle peut avoir l'une des valeurs suivantes :

- **ACCEPT** : le Firewall autorise le paquet
- **DROP** : le paquet est rejeté sans avertir l'émetteur
- **REJECT** : le paquet est rejeté et l'émetteur est averti de l'échec de l'envoi

Les règles de filtrage sont stockées dans des listes. Si un paquet correspond à une règle, celle-ci est appliquée et les autres règles de la liste sont échappées. Sinon, les autres règles sont vérifiées jusqu'à trouver une règle applicable. Si aucune règle ne s'applique au paquet, le Firewall applique la politique par défaut.

Example :

Règle 1 : ACCEPT si condition1
Règle 2 : ACCEPT si condition2
Règle 3 : DROP si condition3
Règle 4 : ACCEPT si condition4
Règle 5 : ACCEPT si condition5
Règle par défaut : DROP

Il y a deux politiques par défaut possibles :

- Interdire tout : tout le trafic sera bloqué sauf le trafic autorisé par les règles précédentes
- Autoriser tout : tout le trafic sera autorisé sauf le trafic bloqué par les règles précédentes

La première politique (Interdire tout) est plus sûre mais nécessite une définition précise des communications à autoriser.

Exemple 1 :

Règle	Action	IP source	IP destination	Protocole	Port source	Port destination
1	ACCEPT	ANY	195.22.44.8	TCP	ANY	80
2	ACCEPT	195.22.44.8	ANY	TCP	80	ANY
3	DROP	ANY	ANY	ANY	ANY	ANY

Politique par défaut : Interdire tout

Trafic autorisé : HTTP (protocole TCP et port 80)

Exemple 2 :

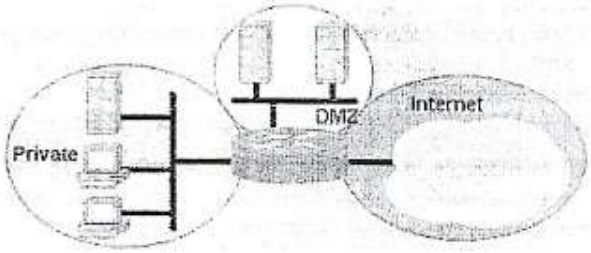
Liste de filtrage permettant d'autoriser tout le trafic sauf les communications Telnet (TCP et port 23) :

Règle	Action	IP source	IP destination	Protocole	Port source	Port destination
1	DROP	ANY	ANY	TCP	ANY	23
2	DROP	ANY	ANY	TCP	23	ANY
3	ACCEPT	ANY	ANY	ANY	ANY	ANY

Conception de la sécurité du réseau basée sur les zones

Une zone de sécurité doit être configurée pour offrir un certain niveau de sécurité. On considère généralement les 3 zones suivantes :

- **Réseau externe** : C'est le réseau Internet
- **Réseau privé** : un LAN privé qui ne doit pas être accessible depuis l'Internet public
- **Réseau privé démilitarisé** : une zone démilitarisée (DMZ : DeMilitarized Zone), où un serveur Web, système de noms de domaine (DNS) et serveur de messagerie doivent être accessibles à l'Internet public



Un Firewall peut filtrer les paquets selon 2 méthodes principales :

- Filtrage simple des paquets (stateless packet filtering) : le filtrage est basé sur les entêtes des paquets (adresse IP source adresse IP destination, protocole TCP/UDP/ICMP, numéro de port). Le filtrage simple examine les paquets les uns indépendamment des autres. Il correspond à la couche réseau du modèle OSI.
- Filtrage dynamique (stateful packet filtering) : le Firewall mémorise l'état des sessions TCP et filtre les paquets en fonction de leur appartenance à des sessions ouvertes ou non. Ce filtrage est basé sur l'inspection des couches 3 et 4 du modèle OSI. On distingue 4 états différents des paquets : **NEW** (le paquet appartient à une nouvelle session TCP), **ESTABLISHED** (le paquet appartient à une connexion déjà établie), **RELATED** (le paquet dépond d'une session déjà établie et autorisée), **INVALID** (le paquet appartient à une session inconnue).

Les firewalls à états (stateful) sont une évolution des firewalls sans états (stateless). La différence entre ces deux types de firewall réside dans la manière dont les paquets sont contrôlés. Les firewalls à états prennent en compte la validité des paquets qui transitent par rapport aux paquets précédemment reçus. Ils gardent alors en mémoire les différents attributs de chaque connexions (adresses IP, numéros de port, numéros de séquence, etc), de leur commencement jusqu'à leur fin, c'est le mécanisme de stateful inspection. De ce fait, ils seront capables de traiter les paquets en fonction de l'état de la session : NEW, ESTABLISHED, RELATED et INVALID.

Exemple de Firewall : Netfilter + iptables

- iptables est un programme de gestion des règles de filtrage. Il gère 3 listes par défaut (INPUT, OUTPUT, FORWARD). Il permet de créer des règles et les ajouter aux différentes listes.
- Netfilter est un programme de filtrage des paquets. Il utilise les listes et les règles gérées par iptables pour filtrer les paquets.

⇨ « Netfilter + iptables » forment un système Firewall installé par défaut sur Linux.

e) Le Firewall iptables/netfilter

Les programmes « **iptables + netfilter** » représentes un firewall personnel disponible sur Linux. Ce firewall support le filtrage simple et dynamique (stateless et statefull). **iptables** sert à manipuler (créer, modifier et supprimer) les règles de filtrage. Il sauvegarde ces règles dans des listes. Une liste s'appelle également "chaîne" (CHAIN). Les règles d'une liste sont analysées les unes après les autres dans l'ordre de leur création. Dès qu'une règle est applicable sur un paquet, elle est exécutée, et les autres règles de la liste sont ignorées.

iptables définit 3 listes de filtrage par défaut : **INPUT, OUTPUT, FORWARD.** Ces listes sont regroupées dans la table **FILTER.** Lorsque la machine fonctionne en tant que routeur, les paquets routés (ne sont pas destinés à la machine) sont filtrés par les règles de la liste **FORWARD.** La liste **INPUT** permet de filtrer les paquets entrants (reçus par la machine) et la liste **OUTPUT** sert à filtrer les paquets sortants (envoyés par la machine).

Il y a 3 actions possibles sur un paquet :

- **ACCEPT** : le paquet est accepté
- **DROP** : le paquet est refusé sans notification à l'émetteur
- **REJECT** : le paquet est refusé mais avec notification à l'émetteur

Chaque liste doit avoir une politique par défaut (c'est à dire une règle qui s'applique lorsqu'aucune des règles de la liste n'est applicable). Il y a 2 politiques par défaut possibles :

- Autoriser tous les paquets qui n'ont pas été bloqués par les autres règles de filtrage
- Interdire tous les paquets qui n'ont pas été autorisés par les autres règles de filtrage

A l'aide des règles de chaque liste, il est possible d'autoriser ou d'interdire l'accès aux différents services réseaux. Il est également possible de modifier la politique de filtrage des différentes listes. La documentation de « **iptables** » est accessible sur https://linux.die.net/man/8/iptables ou en tapant :

```
# man iptables
```

Exemples d'utilisation de « iptables » :

- `iptables -F` : supprime toutes les règles de toutes les listes
- `iptables -X` : conserve les 3 listes de filtrage par défaut (**INPUT, OUTPUT** et **FORWARD**) et supprime toutes les autres.
- `iptables -nL` : affiche toutes les règles de filtrage de toutes les listes disponibles

- `iptables -P INPUT ACCEPT` : la politique par défaut de la liste INPUT est ACCEPT
- `iptables -P INPUT DROP` : la politique par défaut de la liste INPUT est DROP
- `iptables -A INPUT -p icmp -j DROP` : ajoute une règle (à la fin de la liste INPUT) permettant de bloquer le trafic ICMP entrant (la liste INPUT gère le trafic entrant)
- `iptables -I INPUT -p icmp -s 1.2.3.4 -j ACCEPT` : ajoute une règle (au début de la liste INPUT) permettant d'accepter le trafic ICMP venant de l'IP source 1.2.3.4
- `iptables -A INPUT -p tcp --sport 80 -j ACCEPT` : ajoute une règle permettant d'accepter le trafic http entrant (protocole TCP et port source 80)
- `iptables -A OUTPUT -p tcp --dport 80 -j ACCEPT` : ajoute une règle permettant d'accepter le trafic http sortant (protocole TCP et port destination 80)
- `iptables -I INPUT -s 1.2.3.4 -j DROP` : ajoute une règle (au début de la liste INPUT) permettant de bloquer tout trafic venant de l'IP source 1.2.3.4

Exemple 1 :

La commande **ping** permet de vérifier si une machine du réseau est joignable. Cette commande utilise le protocole ICMP. L'objectif de cet exemple est d'autoriser tout le trafic, d'autoriser la commande **ping** vers l'adresse IP « **8.8.8.8** » et de bloquer cette commande vers toutes les autres adresses IP.

1) Effacer toutes les règles de filtrage et toutes les listes secondaires, et afficher l'état des 3 listes de filtrage par défaut.

```
iptables -F
iptables -X
iptables -nL
```

2) Définir la politique par défaut « Autoriser tout » pour les 3 listes.

```
iptables -P INPUT ACCEPT
iptables -P OUTPUT ACCEPT
iptables -P FORWARD ACCEPT
```

3) Ecrire les règles permettant de bloquer la commande **ping** vers toutes les machines (La commande ping utilise le protocol ICMP. Il faut donc bloquer le trafic ICMP).

```
iptables -A INPUT -p icmp -j DROP
iptables -A OUTPUT -p icmp -j DROP
iptables -A FORWARD -p icmp -j DROP
```

4) Ecrire les règles permettant d'autoriser la commande ping uniquement vers l'adresse IP « 8.8.8.8 ».

```
iptables -I INPUT -p icmp -s 8.8.8.8 -j ACCEPT
iptables -I OUTPUT -p icmp -d 8.8.8.8 -j ACCEPT
iptables -I FORWARD -p icmp -d 8.8.8.8 -j ACCEPT
```


Exercice 2 :

Objectif de l'exemple : le poste de travail peut seulement surfer sur Internet (autoriser le trafic web : HTTP, HTTPS et DNS), et tout autre trafic doit être bloqué.

1) Effacer les règles précédentes et afficher l'état des 3 listes.

```
iptables -F
iptables -X
iptables -nL
```

2) Définir la politique par défaut « Interdire tout ».

```
iptables -P INPUT DROP
iptables -P OUTPUT DROP
iptables -P FORWARD DROP
```

3) Ecrire les règles de filtrage permettant d'autoriser le trafic web (http, https et dns).

Les 4 commandes suivantes permettent d'autoriser un trafic http vers et depuis un serveur web (http utilise le protocole TCP et le serveur utilise le port 80)

```
iptables -A INPUT -p tcp --sport 80 -j ACCEPT
iptables -A OUTPUT -p tcp --dport 80 -j ACCEPT
iptables -A FORWARD -p tcp --sport 80 -j ACCEPT
iptables -A FORWARD -p tcp --dport 80 -j ACCEPT
```

Les 4 commandes suivantes permettent d'autoriser un trafic https vers et depuis un serveur web (https utilise le protocole TCP et le serveur utilise le port 443)

```
iptables -A INPUT -p tcp --sport 443 -j ACCEPT
iptables -A OUTPUT -p tcp --dport 443 -j ACCEPT
iptables -A FORWARD -p tcp --sport 443 -j ACCEPT
iptables -A FORWARD -p tcp --dport 443 -j ACCEPT
```

Les 4 commandes suivantes permettent d'autoriser un trafic dns (dns permet de convertir une URL en une adresse IP et utilise le protocole UDP et le port 53)

```
iptables -A INPUT -p udp --sport 53 -j ACCEPT
iptables -A OUTPUT -p udp --dport 53 -j ACCEPT
iptables -A FORWARD -p udp --sport 53 -j ACCEPT
iptables -A FORWARD -p udp --dport 53 -j ACCEPT
```

7) Services et mécanismes de sécurité

Un service de sécurité permet d'améliorer la sécurité des systèmes informatiques et des transferts d'informations. Les services de sécurité sont conçus pour protéger contre les attaques. Ils permettent d'atteindre l'objectif de la sécurité informatique. Ils utilisent les mécanismes de sécurité pour leur bon fonctionnement.

Un mécanisme de sécurité est un moyen permettant de détecter, prévenir et rattraper une attaque informatique. Un seul mécanisme ne peut pas fournir tous les services de sécurité.

a) Les services de sécurité

- **Authentification** : vérifie que la communication est authentique et que l'utilisateur est bien celui qu'il prétend être (mot de passe, empreinte, certificat numérique).
- **Confidentialité** : interdit l'interception ou l'accès aux données et protège contre les attaques actives et passives. La confidentialité est assurée moyennant le chiffrement.
- **Intégrité** : empêche la modification des données et garantie que les messages n'ont subi aucune modification lors de l'envoi.
- **Non-répudiation** : empêche l'émetteur et le récepteur de nier l'envoi d'un message.
- **Contrôle d'accès** : permet de s'assurer que l'utilisateur est bien habilité à utiliser les ressources du système et de lui définir ses droits d'accès. L'utilisateur doit passer d'abord par une étape d'authentification.
- **Disponibilité** : permet au système d'être accessible et utilisable par des personnes autorisées. Ce service est assuré par les mécanismes de détection et de prévention d'actions malveillantes.

b) Mécanismes de sécurité

Parmi les mécanismes de sécurité, on peut citer les exemples suivants :

- **Chiffrement** : transforme les données en une forme illisible
- **Signature numérique** : données ajoutées à un message permettant la vérification de l'origine et de l'intégrité du message.
- **Certificat numérique** : un document signé numériquement contenant l'identité du propriétaire du certificat, son adresse, sa clé publique, etc.